W14D1

Password Cracking e Malware

Emma Rullo

Sommario

Il report si articola in tre parti. Nella prima è descritto il cracking con John the Ripper degli hash MD5 delle password estratti nell'esercizio precedente tramite SQL injection, recuperandone la versione in chiaro con un attacco a dizionario. La seconda parte descrive come rispondere a un sistema Windows infettato dal ransomware WannaCry, con le possibili opzioni di messa in sicurezza e i relativi pro e contro. La terza parte documenta un attacco DoS con Slowloris dalla macchina Kali verso il web server di Metasploitable, con il confronto tra la connettività HTTP e TCP durante l'attacco.

Il laboratorio usa Kali Linux (attaccante, 192.168.50.100) e Metasploitable (vittima, 192.168.50.101).

1. Password Cracking con John the Ripper

1.1 Gli hash dalla SQL injection

Tramite una *UNION query* sulla SQL injection della DVWA, sono stati estratti username e password degli utenti. Osservando le password, non sono in chiaro ma hanno l'aspetto di hash MD5 (stringhe esadecimali di 32 caratteri).

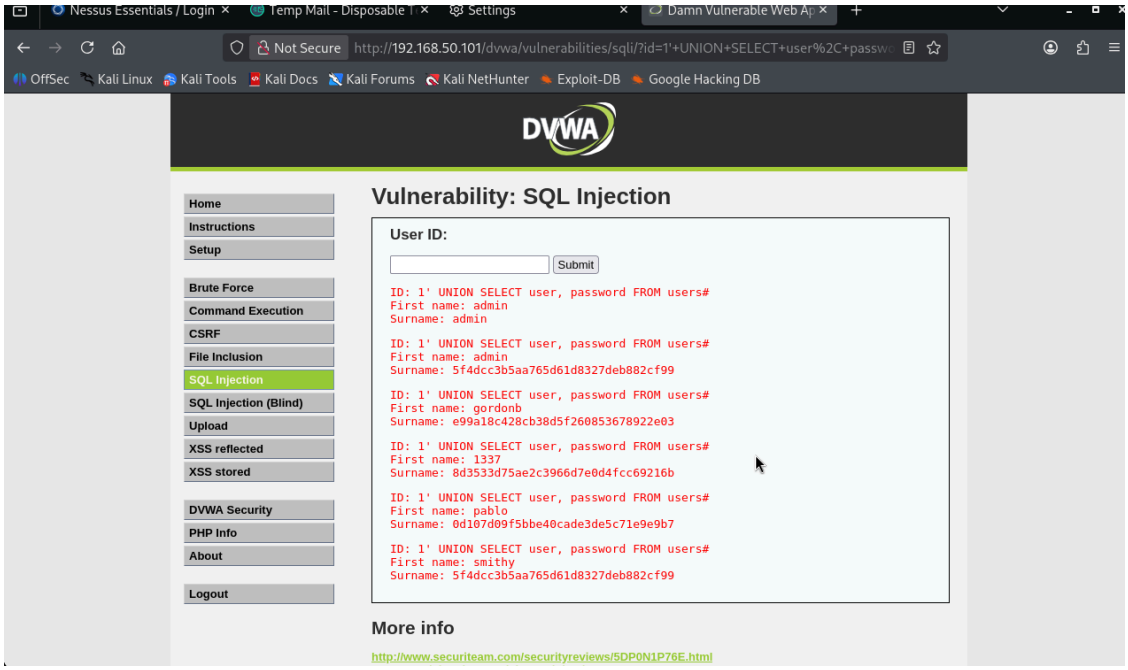


Figura 1 — Hash delle password estratti dal database tramite UNION-based SQL injection

```
admin   : 5f4dcc3b5aa765d61d8327deb882cf99

gordonb : e99a18c428cb38d5f260853678922e03

1337    : 8d3533d75ae2c3966d7e0d4fcc69216b

pablo   : 0d107d09f5bbe40cade3de5c71e9e9b7

smithy  : 5f4dcc3b5aa765d61d8327deb882cf99
```

1.2 Tipologia e meccanismo del cracking

MD5 è una funzione di hash crittografica: trasforma un input di qualsiasi lunghezza in un'impronta fissa di 128 bit ed è a senso unico, ossia dall'hash non si può "tornare indietro" alla password con un calcolo diretto. Per questo il cracking non decifra l'hash, ma procede per tentativi: si prendono molte password candidate, si calcola l'MD5 di ciascuna e lo si confronta con l'hash bersaglio; quando due coincidono, la password candidata è quella giusta.

La tecnica usata è l'attacco a dizionario (dictionary attack): invece di provare tutte le combinazioni possibili (brute force puro), si usa una *wordlist,* cioè un elenco di password comuni e già trapelate. Qui si usa rockyou.txt, la celebre lista derivata da un data breach, contenente milioni di password reali. Lo strumento è John the Ripper, che calcola l'hash di ogni parola della wordlist e lo confronta con quelli nel file bersaglio.

Gli hash MD5 della DVWA sono inoltre non salati: non c'è un "sale" casuale aggiunto alla password prima dell'hashing, quindi password identiche producono hash identici (come admin e smithy) e il cracking è molto più rapido, perché due hash uguali si risolvono in un colpo solo.

1.3 Esecuzione e risultato

Si crea un file hash.txt contenente solo i cinque hash, uno per riga (senza username o altri caratteri, altrimenti John non li riconosce). Poi si lancia il cracking specificando il formato raw-md5, la wordlist e il file:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt ~/Desktop/hash.txt

john --show --format=raw-md5 ~/Desktop/hash.txt
```

dove --format indica il tipo di hash, --wordlist il dizionario e l'ultimo argomento il file con gli hash. Il comando --show mostra le password già craccate.

Su Kali la wordlist va prima scompattata con

```
sudo gunzip -k /usr/share/wordlists/rockyou.txt.gz
```

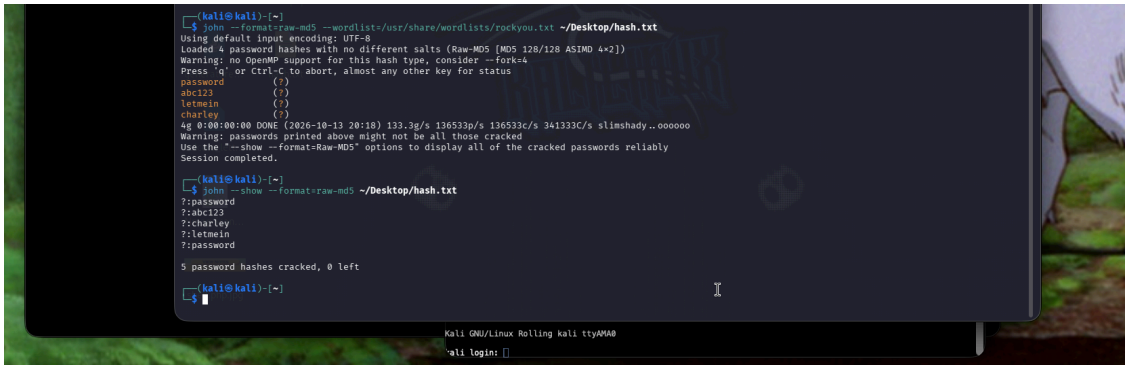


Figura 2 — Esecuzione di John the Ripper e output di --show: 5 hash craccati, 0 rimanenti

Risultato: 5 password hashes cracked, 0 left. Le password in chiaro sono:

- admin → password
- gordonb → abc123
- 1337 → charley
- pablo → letmein
- smithy → password (identica ad admin, come previsto dall'hash uguale)

Tutte password deboli e presenti in rockyou quindi password comuni e hash MD5 non salati sono una combinazione insicura.

2. Risposta a un'infezione WannaCry

Scenario: un computer Windows dell'azienda cliente risulta infettato dal ransomware WannaCry. WannaCry cifra i file della vittima chiedendo un riscatto e si propaga nella rete sfruttando la vulnerabilità *EternalBlue* del protocollo SMBv1.

2.1 Intervento immediato sul sistema infetto

- Disconnettere subito il computer dalla rete (cavo e Wi-Fi) per impedire la propagazione ad altre macchine.
- Isolare fisicamente la macchina infetta dagli altri dispositivi.
- Se possibile, avviare un backup offline dei dati critici ancora integri (su supporto non riscrivibile dal malware).
- Notificare il team IT e il management dell'incidente di sicurezza, documentando orari e sintomi.

2.2 Opzioni di messa in sicurezza, pro e contro

Dopo il contenimento, si valutano le possibili strade per ripristinare il sistema in sicurezza:

Opzione	Pro	Contro
Formattazione e reinstallazione pulita	Rimuove con certezza il malware; sistema come nuovo	Si perdono tutti i dati non salvati; tempo e riconfigurazione necessari
Ripristino da backup precedente all'infezione	Recupera dati e configurazioni; relativamente veloce	Efficace solo con backup sani e aggiornati; si perde il lavoro successivo al backup
Strumenti di rimozione malware specializzati	Può salvare il sistema senza formattare; meno invasivo	Nessuna garanzia di rimozione completa; i file già cifrati restano inaccessibili
Aggiornamento a un OS più recente e supportato	Chiude la vulnerabilità alla radice (SMBv1/EternalBlue); maggiore sicurezza futura	Possibili incompatibilità software/hardware; costi e tempi di migrazione

In pratica, la scelta più sicura per un sistema già compromesso è la formattazione e reinstallazione pulita, seguita dal ripristino dei soli dati da un backup verificato e dall'applicazione immediata delle patch (in particolare quella per SMBv1) e di un OS supportato, così da non ricadere nella stessa vulnerabilità.

3. Attacco DoS con Slowloris

3.1 DoS, DDoS e Slowloris

DoS (Denial of Service): attacco che mira a rendere un servizio o un sito inaccessibile sovraccaricandolo di richieste. Un singolo computer invia un gran numero di richieste al server, esaurendone le risorse (CPU, memoria, banda) e interrompendo il servizio.

DDoS (Distributed Denial of Service): simile al DoS, ma l'attacco proviene da molte fonti distribuite, spesso una botnet (rete di computer infetti). Essendo distribuito su molti IP e località, è molto più difficile da bloccare.

Slowloris: è un attacco DoS/DDoS che mantiene aperte molte connessioni HTTP verso il server per lunghi periodi. L'attaccante invia richieste *incomplete* (header parziali, keep-alive continui) impedendo che le connessioni vengano chiuse: satura gradualmente il pool di connessioni del web server senza consumare molta banda. In questo esercizio si valuta l'efficacia di Slowloris da un solo attaccante (Kali), senza botnet.

3.2 Avvio dell'attacco

Dopo aver verificato la raggiungibilità del target con un ping, è stato clonato il tool e lanciato verso Metasploitable. Di default usa 150 socket.

```
git clone https://github.com/gkbrk/slowloris

cd slowloris

python3 slowloris.py 192.168.50.101
```

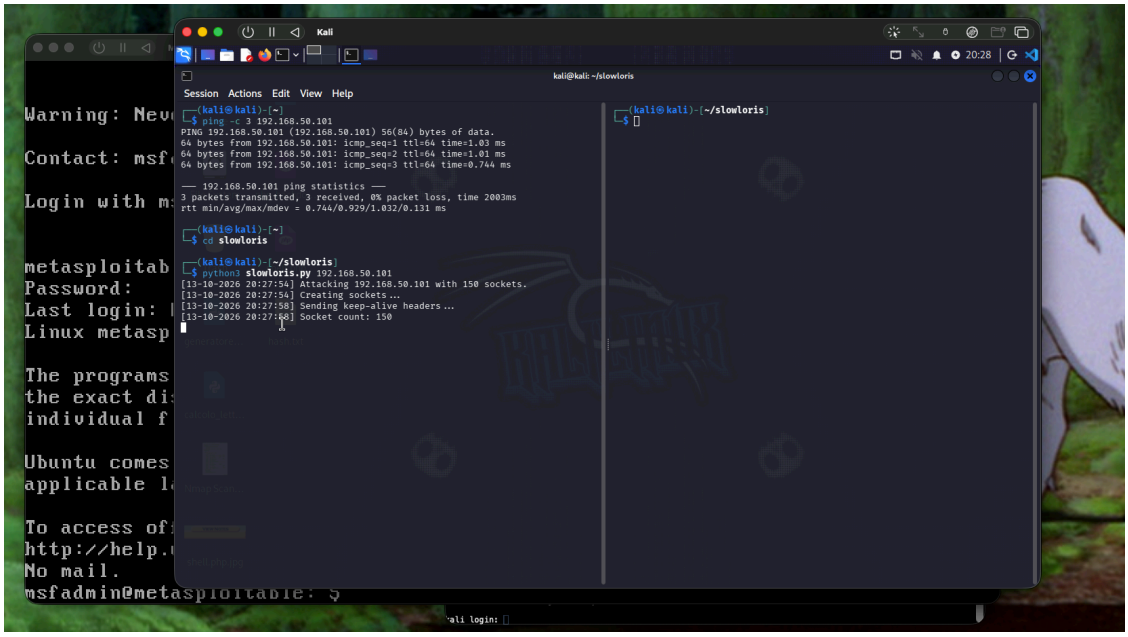


Figura 3 — Avvio di Slowloris contro 192.168.50.101 con 150 socket: invio continuo di keep-alive headers

3.3 Monitoraggio della connettività HTTP (watch + curl)

In un secondo terminale è stata monitorata la risposta HTTP del web server, stampando ogni secondo solo l'header della risposta ed evidenziando le differenze:

```
watch -n 1 --differences 'curl -I --max-time 2 http://192.168.50.101 --silent'
```

Con il server raggiungibile, curl riceve HTTP/1.1 200 OK e la riga Date: cambia a ogni ciclo. Quando Slowloris satura il web server, curl non riceve più risposta: l'header sparisce e curl va in timeout (codice di uscita 28). Il contrasto tra i due stati dimostra il DoS riuscito.

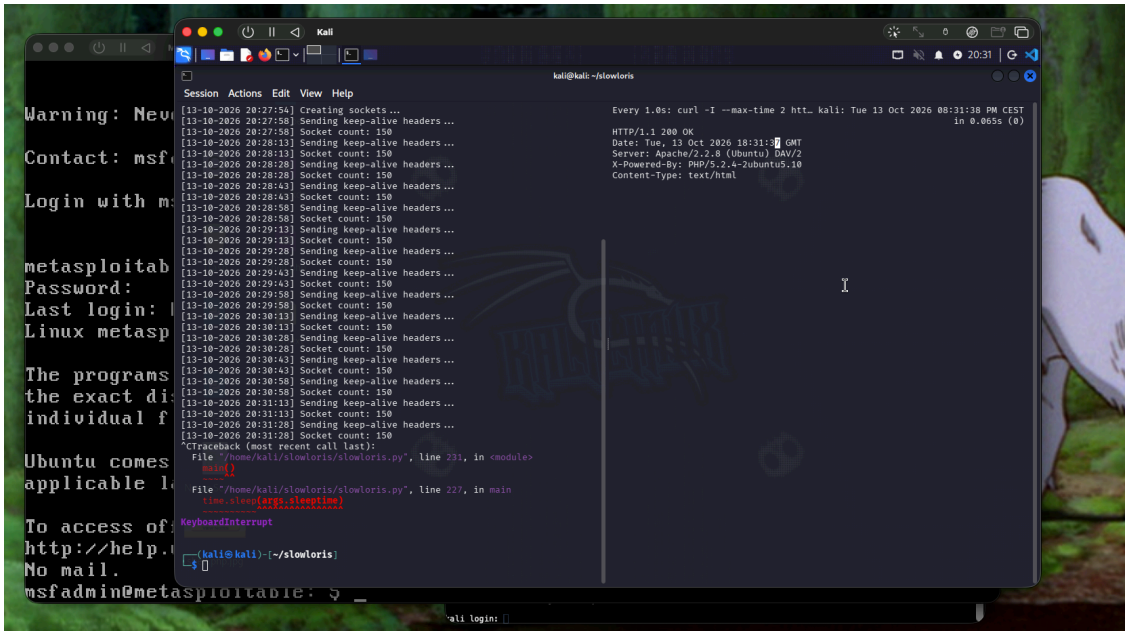


Figura 4 — Server raggiungibile (Slowloris fermo): HTTP/1.1 200 OK con Date che avanza, risposta in 0.065s

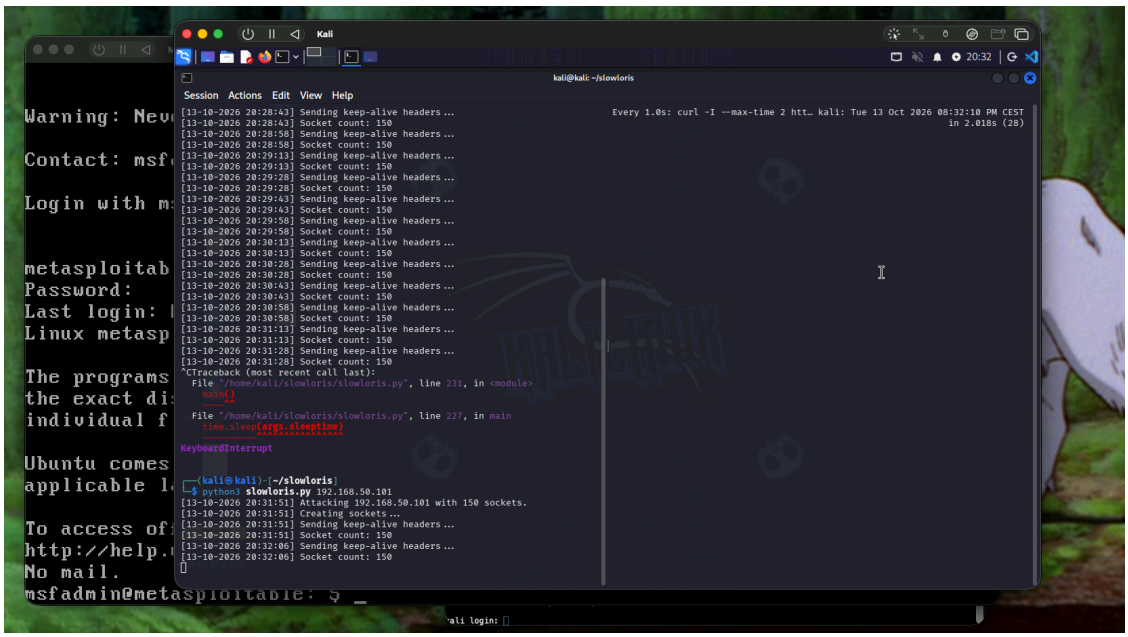


Figura 5 — DoS attivo (Slowloris a 150 socket): nessuna risposta, curl va in timeout (28) — il web server non risponde più

3.4 Monitoraggio della connettività TCP

È stata quindi monitorata la connettività TCP alla porta 80 con tcping. È stata installata la versione Python tramite pipx (pipx install tcping).

```
tcping -p 80 192.168.50.101
```

Con Slowloris a 150 socket, mentre l'HTTP è già saturo e non risponde, il TCP continua a rispondere (10 connessioni su 10 riuscite, 100%). Questo perché Slowloris esaurisce il pool di worker HTTP di Apache (livello application), ma lo stack TCP del sistema operativo (livello transport) accetta ancora le connessioni. È la differenza tra i due livelli.

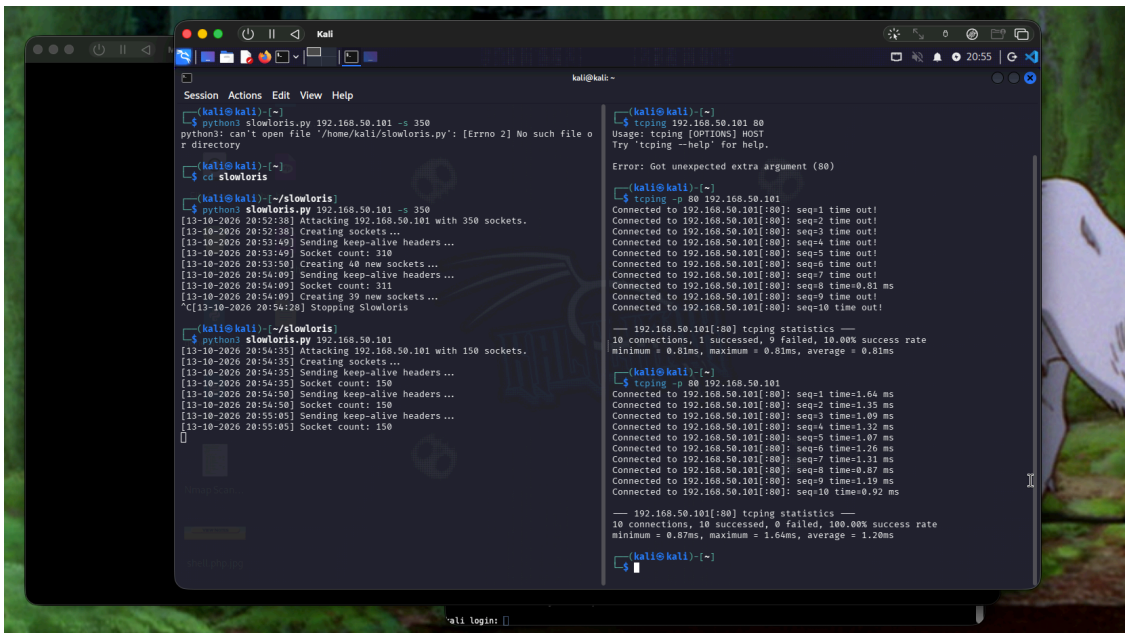


Figura 6 — Con Slowloris a 150 socket: tcping riporta 10/10 connessioni riuscite (100%) — il TCP risponde ancora mentre l'HTTP è saturo

Aumentando la pressione con più socket (-s specifica il numero di socket), anche il livello TCP inizia a cedere: con 350 socket tcping registra quasi solo timeout.

```
python3 slowloris.py 192.168.50.101 -s 350
```

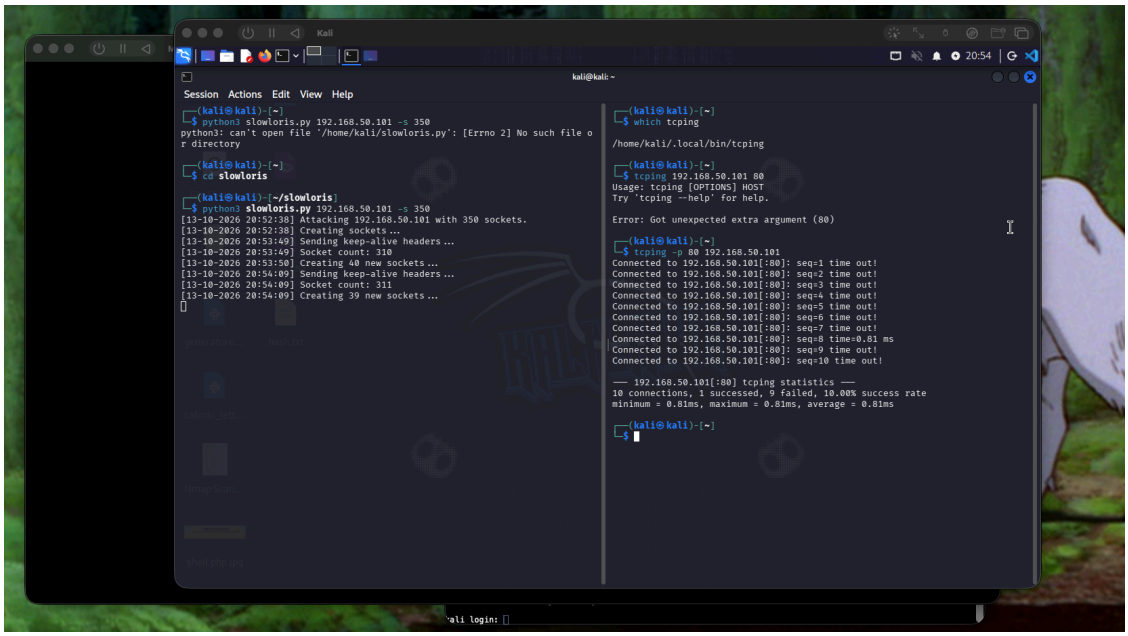


Figura 7 — Con Slowloris a 350 socket: tcping riporta solo 1/10 connessioni riuscite (10%), quasi tutte in timeout — sotto forte pressione cede anche il TCP

3.5 Difese contro Slowloris

- Impostare timeout più aggressivi sulle connessioni e limitare il tempo di invio degli header (es. mod_reqtimeout su Apache).
- Limitare il numero di connessioni concorrenti per singolo IP (mod_qos, limiti del web server).
- Usare un reverse proxy / web server che bufferizza le richieste (nginx) o un WAF/anti-DDoS davanti al server.
- Mantenere aggiornato il web server: Metasploitable usa Apache 2.2.8 del 2008, particolarmente vulnerabile.